

Mapa de Risco – Plataforma da Collab de Lojas

Alunos: Gabriel Vitório, Lucas Leal e Yuri Cidral

1. Contexto do Sistema

A plataforma permite que várias lojas colaborem em um mesmo sistema, compartilhando informações como:

- Cadastro de lojas
- Cadastro de produtos
- Pedidos
- Dados do cliente
- Relatórios de vendas
- Gestão administrativa

Stack tecnológica:

Frontend: React

Backend: Node.js / TypeScript

Banco de dados: Supabase

Infraestrutura: Docker

Ferramentas: Github, Jira, Postman, Github Actions

2. Classificação de Riscos

Os riscos serão classificados em:

-Probabilidade

- Baixa
- Média
- Alta

-Impacto:

- Baixo
- Médio
- Alto

- Crítico

-Nível de risco:

- Baixo
- Médio
- Alto
- Muito alto

ID	Risco	Probabilidade	Impacto	Nível de risco
R1	Vazamento entre lojas	Média	Crítico	Muito alto
R2	Vazamento de dados sensíveis	Média	Crítico	Muito alto
R3	Falha de autenticação	Média	Alto	Alto
R4	Controle de acesso inadequado	Alta	Crítico	Muito alto
R5	Injeção de código (SQL/ Script)	Média	Alto	Alto
R6	Permissões incorretas no banco	Média	Alto	Alto
R7	Exposição de Secrets (API Keys/ tokens)	Média	Alto	Alto
R8	Dependências vulneráveis	Alta	Médio	Alto
R9	Ataque DDoS	Baixa	Alto	Médio
R10	Perda de dados	Baixa	Crítico	Alto
R11	Engenharia social contra administradores	Média	Alto	Alto
R12	Erros de configuração da infraestrutura	Média	Alto	Alto
R13	Falha em backup ou recuperação	Baixa	Crítico	Alto

R14	Ataques de força bruta no login	Média	Médio	Médio
R15	Upload malicioso de arquivos	Média	Alto	Alto

4. Detalhamento dos Riscos

R1. Vazamento de dados entre lojas

Descrição: Uma loja pode acabar acessando dados de outra loja.

Causa:

Arquitetura multi-tenant mal implementada.

Impacto

- Exposição de dados comerciais.
- Violação de privacidade
- Quebra de confiança
- Problemas legais (LGPD)

Mitigação:

- Isolamento por tenant_id
- RLS no banco
- Testes de segurança automatizados

R2. Vazamento de Dados Sensíveis

Dados afetados:

- Dados de clientes
- Emails
- Histórico de compras
- Dados financeiros

Impacto:

- Multas LGPD
- Danos a Reputação
- Perda de clientes

Mitigação:

- Criptografia (HTTPS)
- Anonimização em logs
- Controle de acesso por função

R3. Falha de Autenticação

Causa:

- Autenticação fraca
- Sessão mal gerenciada
- Token exposto

Mitigação:

- JWT com expiração curta
- Refresh tokens
- MFA para admins
- Revogação de sessões

R4. Controle de acesso inadequado

Descrição: Usuários com permissões maiores do que deveriam

Causa

- Má estruturação de níveis de autoridade.

Mitigação:

- Role based access control
- Auditoria de permissões

R5. Injeção de Código

Tipos Possíveis:

- SQL Injection

- NoSQL Injection
- XSS
- Command Injection

Mitigação:

- Validação de entrada
- Escape automatico no frontend

R6. Configuração Incorreta do Banco

Exemplo:

- Tabela pública
- Permissões abertas
- Acesso direto no banco

Mitigação:

- Políticas de acesso
- Roles separadas
- Revisão de permissões

R7 – Exposição de Secrets

Segredos possíveis:

- Tokens
- Keys de API
- Credenciais do banco
- Chaves de serviço

Mitigação:

- Secret manager
- Evitar upar segredos no git
- Rotação de chaves importantes

R8. Dependências vulneráveis

Causa:

Bibliotecas com vulnerabilidades conhecidas.

Mitigação:

- Scan automático
- Atualização periódica
- Auditoria de pacotes

R9. Ataque DDOS

Consequência:

- Indisponibilidade o sistema
- Perda de vendas

Mitigação:

- Firewall
- Proteção conta DDoS

R10 – Perda de dados

Causa:

- Falha no banco
- Erro humano
- Bugs

Mitigação:

- Backup diário
- Criação de snapshots

R11- Engenharia social contra administradores

Causa: pessoa mal-intencionado tenta manipular ou roubar informação de algum administrador

Impacto:

- Acesso admin indevido
- Roubo de dados
- Alteração de informações do sistema
- Exclusão de registros

Mitigação:

- MFA obrigatório para Admins
- Verificação de identidade para redefinição de senha

R12- Erros de configuração de infraestrutura

Descrição: configuração incorreta de servidor, container e serviços que possam expor o sistema

Impacto:

- Invasão do servidor
- Acesso ao banco de dados
- Interrupção do sistema

Mitigação:

- Firewall configurado
- Revisão periódica de infraestrutura

R13- Falha em backup ou recuperação

Descrição: Falha na restauração de dados

Impactos:

- Perda de dados
- Interrupção do sistema

Mitigação:

- Backups automáticos
- Armazenamento em local seguro
- Versionamento de backups

R14 – Ataques de força bruta no login

Descrição: tentativa automática de descobrir senhas com diferentes combinações

Impacto:

- Acesso indevido ao sistema
- Comprometimento de contas

Mitigação:

- Bloqueio temporário após várias tentativas
- MFA

R15 – Upload malicioso de arquivos

Descrição: usuários tentam enviar arquivos maliciosos para o sistema

Impacto:

- Execução do código malicioso
- Invasão do servidor

Mitigação:

- Limitar tipo de arquivo
- Limite de tamanho de upload
- Armazenamento separado de upload

Controles de Segurança Implementados

Autenticação

- JWT
- MFA
- Política de senha forte

- Bloqueio de tentativa de login

Proteção de API

- Rate limit
- Validação de entrada
- Autenticação obrigatória

Proteção de dados

- HTTPS obrigatório
- Criptografia
- Mascaramento de logs

Infraestrutura

- Docker
- CI/CD seguro
- Scans automaticos

Monitoramento e Auditoria

Sistema deverá registrar:

- Logins
- Alterações administrativas
- Falhas de autenticação
- Acessos de dados sensíveis

Normas de Segurança Seguida

O sistema seguirá padrões internacionais:

- ISO 27001
- LGPD

Responsabilidade Ética

O sistema deve garantir:

- Privacidade de clientes
- Transparência no uso de dados
- Coleta mínima de dados
- Direito de exclusão de dados
- Uso responsável de informações